

REPORT 1

Risk Assessment Report for TechSolutions

Risk Score	Likelihood	Impact	Justification (IT Context)
1. Phishing			
5/5 (Extreme Risk)	High	Catastrophic	Phishing is the #1 initial attack vector for modern cyber incidents, especially for IT organizations that are targeted for their high-value data and access to client networks.
2. Weak Password Sharing			
4/5 (Very High Risk)	Moderate to High	Major	Sharing one weak password can immediately compromise an entire system, leading to Account Takeover and loss of accountability.
3. Unsanctioned Software Installation (Shadow IT)			
4/5 (Very High Risk)	High	Major to Catastrophic	Directly undermines IT control, opens unpatched vulnerability entry points, and can violate critical client/software licensing agreements.

DETAILED JUSTIFICATION FOR 1:

- **Likelihood (High):**
 - **Human Factor:** Phishing exploits the single weakest link in security—the employee. Even with advanced filters, sophisticated **Spear Phishing** attacks targeting IT staff (who have elevated access) are common and highly effective.
 - **Prevalence:** Security reports consistently show phishing as the most frequent initial access method for corporate breaches. It is a daily, ubiquitous threat.
- **Impact (Catastrophic):**
 - **Business Continuity:** Successful phishing can lead to **Ransomware infection** (locking down all critical development and client-facing systems) or **Business Email Compromise (BEC)**, directly halting operations and service delivery.
 - **Financial:** High-stakes losses from fraudulent wire transfers (BEC) or massive costs for incident response, forensic analysis, system rebuilds, and paying a ransom. The average cost of a breach is in the millions.
 - **Reputation:** A breach is devastating for an IT company, whose core business is *trust* and *security*. Loss of client data or IP can lead to lawsuits, regulatory fines (e.g., GDPR), and an irreparable loss of client confidence, resulting in significant customer churn.

DETAILED JUSTIFICATION FOR 2:

- **Likelihood (Moderate to High):**
 - **Work Culture:** In fast-paced IT environments, teams often share passwords for administrative accounts, test accounts, or shared collaboration tools to "increase efficiency." This creates a single point of failure.
 - **Credential Stuffing:** A single employee reusing a weak password from a public breach dump can be targeted by automated **Credential Stuffing** attacks, which check those username/password combinations against work accounts.
- **Impact (Major):**
 - **Business Continuity:** Sharing a privileged account password means an attacker gaining access can bypass standard security controls, perform unauthorized configuration changes, or install malware, causing system downtime. The lack of individual accountability also slows down incident response.
 - **Financial:** Costs from system damage, data loss, and IT support time spent on frequent password resets and account lockouts.
 - **Reputation:** Weak password practices are a common root cause of breaches (over 80% involve stolen/weak credentials). This indicates a failure in basic security hygiene, which severely damages the company's image and compliance posture (e.g., losing the audit trail required by many regulations).

DETAILED JUSTIFICATION FOR 3:

Likelihood (High):

- **IT Culture:** IT employees, particularly developers, often download tools, libraries, and open-source software (freeware, trial versions, or "Shadow IT" apps like unauthorized cloud storage or messaging) to work around perceived roadblocks or to find a "faster" solution. This behavior is driven by a desire for efficiency but creates massive risk.
- **Volume of Assets:** An IT organization has a large, dynamic fleet of workstations and servers. Manually tracking every piece of installed software is nearly impossible without automated tools, making unauthorized installation frequent.

Impact (Major to Catastrophic):

- **Business Continuity:**
 - **Malware & Backdoors:** Unsanctioned software (especially pirated/cracked versions) is a primary vector for Trojan horses and malware (like cryptojacking

software or keystroke loggers). This can bypass existing endpoint protection and lead to a full network compromise.

- System Instability: Unapproved software can conflict with existing business-critical applications (e.g., development environments or internal project tools), leading to system crashes, data corruption, and significant downtime.

- **Financial:**

- Fines & Audits: Installing unlicensed or pirated software exposes the company to massive software license non-compliance fines from organizations like the Business Software Alliance (BSA), often in the tens of thousands or more.
- Incident Response: The cost to remediate a malware infection or breach originating from unauthorized software is extremely high (forensics, cleaning, system hardening).

- **Reputation & Compliance:**

- Data Leakage: Employees using unauthorized cloud storage or file-sharing apps to transfer client data bypasses security controls, leading to a major data leak and violation of regulations like GDPR, HIPAA, or client contracts.
- Trust: An IT firm must demonstrate strong control over its environment to its clients. A Shadow IT problem is an immediate red flag in any security audit or client assessment.

REPORT 2

Risk Matrix (Heat Map) for TechSolutions

Step 1: Define Scales

Scale	Likelihood (Frequency)	Impact (Severity)
5 (Extreme)	Happens almost daily/weekly.	Catastrophic failure; loss of mission-critical systems/data; bankruptcy; major fines.
4 (High)	Happens monthly/quarterly.	Major system outage; severe financial loss; significant regulatory fine; major reputation damage.
3 (Medium)	Happens several times per year.	Localized system disruption; moderate financial cost; minor reputation damage.
2 (Low)	Happens once per year or less.	Minor IT disruption; minimal financial cost.
1 (Very Low)	Extremely rare or never.	Negligible impact.

Step 2: Construct the Matrix

	1: Very Low	2: Low	3: Medium	4: High	5: Extreme
5: Catastrophic	5	10	15	20	25
4: Major	4	8	12	16	20
3: Moderate	3	6	9	12	15
2: Minor	2	4	6	8	10
1: Negligible	1	2	3	4	5

Risk Score Range	Color Code	Action Required
20–25	Red	Urgent Action: Requires immediate mitigation and executive attention.
15–19	Orange	High Priority: Requires a dedicated mitigation plan and timeline.
10–14	Yellow	Monitor & Plan: Requires routine monitoring and future planning.
1–9	Green	Accept/Monitor: Acceptable risk level.

Step 3: Plot the Risks (Example Data)

Behavioral Problem	Likelihood (X)	Impact (Y)	Combined Score (X * Y)	Matrix Position
1. Phishing	5 (High)	5 (Catastrophic)	25 (Red)	Extreme Risk
2. Weak Password Sharing	4 (High)	4 (Major)	16 (Orange)	High Risk
3. Shadow IT	4 (High)	4 (Major)	16 (Orange)	High Risk